

Botium Toys Security Audit

Controls & Compliance Assessment

Overview

Conducted an internal security audit for a fictional retail and e-commerce company as part of the Google Cybersecurity Certificate program to evaluate its security posture, identify control gaps, and assess compliance with major frameworks.

Objective

- Assess existing security controls
- Identify risks, threats, and vulnerabilities
- Evaluate compliance with industry standards
- Provide prioritized recommendations to reduce risk

Environment

- Single physical location (office, storefront, warehouse)
- Growing e-commerce presence (U.S. + international customers)
- Internal network + online systems
- Processes customer payment data and personal information

Key Findings

Botium Toys lacks several foundational security controls, including encryption, access control, and data backups. These gaps significantly increase the likelihood of data breaches, regulatory violations, and operational disruption.

The organization is:

- **Non-compliant with PCI DSS**
- **Partially compliant with GDPR**
- **Weakly aligned with SOC 2**
- **Not aligned with the NIST Cybersecurity Framework**

Risk Summary

The organization currently lacks several foundational controls, significantly increasing the likelihood of both internal and external threats. Without remediation, these gaps create substantial risk of regulatory non-compliance, financial loss, and operational disruption.

Risk Acceptance Position

The following risks are **not** acceptable for risk acceptance:

- Lack of encryption for sensitive data
- Absence of access controls (least privilege + separation of duties)
- Lack of data backups

These risks create a high likelihood of:

- Regulatory fines (PCI DSS, GDPR)
- Data breaches
- Business disruption

Final Recommendation

By prioritizing access control, encryption, and data protection measures, Botium Toys can significantly reduce both the likelihood of a breach and the financial and regulatory impact associated with non-compliance.

Immediate (Critical):

- Implement encryption for sensitive data
- Enforce least privilege and separation of duties
- Establish regular data backups

High Priority:

- Strengthen password policies
- Implement password management system
- Deploy intrusion detection system

Medium Priority:

- Develop disaster recovery plan
- Standardize legacy system monitoring

[See next page for full controls and compliance assessment]

Controls Assessment

Administrative / Managerial Controls - HIGH RISK

- **Least Privilege — NO**

Currently, all employees have access to customer and internal data. This violates the principle of least privilege as defined by the NIST Cybersecurity Framework. Access should be restricted based on job responsibilities to prevent unauthorized access, which has a high likelihood of resulting in data exposure, insider threats, and regulatory violations.

- **Disaster Recovery Plans — NO**

There are no disaster recovery plans in place. This fails to meet business continuity expectations outlined in frameworks such as the NIST Cybersecurity Framework. Without a recovery plan, disruptions cannot be effectively managed, which has a high likelihood of resulting in prolonged downtime, financial loss, and operational failure.

- **Password Policies — NO**

Password requirements are minimal and not aligned with modern security standards. This weakens authentication controls recommended by frameworks like ISO/IEC 27001. Weak passwords increase susceptibility to brute-force and credential-based attacks, which have a medium-to-high likelihood of resulting in unauthorized access and account compromise.

- **Separation of Duties — NO**

Separation of duties has not been implemented, allowing individuals to control multiple critical functions. This violates governance best practices outlined in the NIST Cybersecurity Framework. Lack of role separation increases the risk of fraud or misuse of access, which has a medium-to-high likelihood of resulting in undetected malicious activity or data manipulation.

Technical Controls - NEEDS IMPROVEMENT

- **Encryption — NO**

Sensitive data, including credit card information, is not encrypted. This violates core confidentiality requirements outlined in PCI DSS and frameworks such as ISO/IEC 27001. Lack of encryption has a high likelihood of resulting in data exposure in the event of a breach, leading to regulatory penalties and financial loss.

- **Password Management System — NO**

There is no centralized password management system. This increases reliance on insecure practices such as password reuse. This has a medium likelihood of resulting in credential compromise and reduced operational efficiency.

- **Backups — NO**

There are no backups of critical data. This violates availability and recovery expectations in frameworks like the NIST Cybersecurity Framework. Lack of backups creates a high likelihood of irreversible data loss, which can result in business disruption, ransom vulnerability, and operational shutdown.

- **Intrusion Detection System (IDS) — NO**

There is no IDS in place to monitor network activity. This fails to meet the detection capabilities outlined in frameworks such as NIST. Without detection mechanisms, there are likely to be cyber threats that go unnoticed, which has a medium-to-high likelihood of resulting in prolonged attacker presence and vulnerability exploits.

- **Manual Monitoring of Legacy Systems — PARTIAL**

Legacy systems are monitored inconsistently without defined procedures. This does not fully meet control expectations for maintaining outdated systems. This has a medium likelihood of resulting in unpatched vulnerabilities being exploited, leading to potential system compromise.

- **Firewall — YES (*but could be stronger*)**

A firewall is in place and filters traffic based on appropriate, predefined rules. While this aligns with preventative controls in the NIST Cybersecurity Framework, limited visibility into anomalous behavior reduces effectiveness. This has a low-to-medium likelihood of allowing sophisticated threats to bypass detection, potentially resulting in unauthorized network access.

- **Antivirus Software — YES (scope unclear)**

Antivirus software is installed and monitored on on-premises equipment; however, deployment across all systems (i.e. remote workstations, employee equipment/ end-user devices, etc.) is unclear. This partially meets preventative control expectations but could introduce gaps in protection. Depending on the exact implementation, this has a medium likelihood of resulting in undetected malware on unprotected systems.

Physical Controls – GOOD

- **Locks (offices, storefront, warehouse) — YES**

Locks are implemented to restrict physical access, aligning with physical security best practices and reducing unauthorized access risk.

- **Closed-circuit television (CCTV) surveillance — YES**

CCTV systems are in place, serving as both a deterrent and a detection mechanism for physical threats.

- **Fire Detection/Prevention — YES**

Fire safety systems, including fire alarm and sprinkler systems, are implemented, reducing risk of physical asset damage and supporting business continuity.

Compliance Assessment

PCI DSS – Non-Compliant, HIGH RISK

- **Authorized Access to Credit Card Data — NO**

Currently, all employees have access to internal data, including customer credit card information. This violates access control requirements under PCI DSS, which mandate restricting access to cardholder data based on business need-to-know. This has a high likelihood of resulting in unauthorized access, data exposure, and potential financial fraud, leading to regulatory penalties and loss of customer trust.

- **Secure Handling of Credit Card Data — NO**

Credit card data is accepted, processed, and stored internally without proper access restrictions or security controls such as least privilege or at-rest and in-transit encryption. This fails to meet PCI DSS requirements for securing cardholder data environments. This has a high likelihood of resulting in data breaches, which could lead to significant financial penalties, legal liability, and reputational damage.

- **Encryption Procedures — NO**

Sensitive financial data is not encrypted during storage or transmission. This directly violates PCI DSS encryption requirements and confidentiality principles outlined in frameworks such as ISO/IEC 27001. This has a high likelihood of resulting in exposed financial data if intercepted or accessed, leading to severe regulatory consequences and financial loss.

- **Secure Password Management — NO**

Password policies are weak and no centralized password management system is in place. This fails to meet PCI DSS authentication requirements. This has a medium-to-high likelihood of resulting in credential compromise, unauthorized access, and increased attack surface for threat actors.

GDPR – Partially Compliant, MEDIUM-HIGH RISK

- **Customer Data Protection — NO**

Customer data is not adequately protected due to lack of encryption and weak access controls. This violates GDPR requirements for safeguarding personal data. This has a high likelihood of resulting in personal data exposure, which could lead to regulatory fines and legal consequences.

- **Data Classification and Inventory — NO**

While assets are inventoried, they are not properly classified based on sensitivity or criticality. This does not meet GDPR expectations for data governance and risk management. This has a medium likelihood of resulting in improper handling of sensitive data and ineffective protection measures.

- **72-Hour Breach Notification — YES**

A process is in place to notify E.U. customers within 72 hours of a breach. This aligns with GDPR breach notification requirements and reduces regulatory risk in the event of an incident.

- **Privacy Policies Enforcement — YES**

Privacy policies, procedures, and processes are documented and enforced. This aligns with GDPR requirements for accountability and governance.

SOC 2 – Partially Compliant, HIGH RISK

- **User Access Policies — NO**

Access controls such as least privilege and separation of duties are not implemented. This violates SOC 2 trust service criteria related to access control. This has a high likelihood of resulting in unauthorized data access and internal misuse.

- **Data Confidentiality — NO**

Sensitive data is not encrypted and is broadly accessible. This fails to meet SOC 2 confidentiality requirements. This has a high likelihood of resulting in data exposure and loss of customer trust.

- **Data Integrity — YES (*but could be stronger*)**

Data integrity controls are in place, aligning with SOC 2 integrity requirements and supporting business operations. These controls likely include system-level validation, database constraints, and processes that maintain data consistency. However, due to the lack of access controls such as least privilege and separation of duties, there is an increased risk that authorized users could intentionally or unintentionally alter data and compromise data accuracy over time.

- **Data Availability — YES**

Data is accessible and systems are operational, aligning with SOC 2 availability principles. Availability is maintained, though access control weaknesses introduce separate security risks, which may indirectly affect overall system trust and security posture.